

# GDPR Legal Exposure

---

*Cross-domain citizen-record linkage without consent: where it breaches data-protection law — and where it doesn't*

*Analysis from public sources and the text of the GDPR/UK GDPR. Not legal advice — a data-protection solicitor must settle any specific claim. The aim here is the strongest accurate case, because an accurate case has teeth and an overclaim is dismissed on sight.*

**Verdict in one line:** As a blanket claim, "this violates GDPR" is **wrong** — GDPR was written to *permit* the statistical core, and that is the real outrage. But GDPR is **not** a blank cheque, and there are five specific, nameable points of genuine legal exposure. The winning strategy is a **narrow, targeted complaint** on those grounds against a **specific deployment** — not "it's all illegal."

---

## 1. Why the blanket claim fails (state this, so you're credible)

---

A controller will immediately point to: - **Art 6(1)(e)** — "public task" is a lawful basis; **consent is not required**. - **Art 89** — a dedicated regime for **statistical processing** (with safeguards). - **Art 9(2)(j)** — a condition that lets even **health/biometric** ("special category") data be processed for statistics/research. If your case rests on "no consent" or "no opt-out" alone, it **loses here**. Concede this up front — it's what makes the rest land.

## 2. The "no opt-out" question — handled honestly

---

- There **is** a right to object (**Art 21**) to public-task processing — **but Art 21(6) and Art 89 + national derogations curtail it for statistics**. So in practice, for official statistics, **there is often no opt-out — lawfully**.
- That means "no opt-out" is **not a standalone violation**. It is the **grievance** (the law lets the state deny you any say over sensitive linkage) and a **plank in a proportionality/fairness challenge** — not the knockout blow on its own. Frame it that way or it gets swatted.

## 3. The five real doors (where GDPR genuinely bites)

---

**Door 1 — Fairness & transparency (Art 5(1)(a)).** Even *with* a lawful basis, processing must be **fair and transparent**. Mass, invisible, cross-domain linkage that citizens have no awareness of is a live argument that the **transparency and fairness principles are breached regardless of the lawful basis**. *Your strongest general ground.*

**Door 2 — Purpose limitation / function creep (Art 5(1)(b)).** The statistics exemption covers *statistical* use **only**. The moment linked data is used to **identify a named individual operationally** — e.g. real-time matching in court, pulling police/arrest records — it is **no longer statistics**, the Art 89 cover falls away, and you're into processing that needs its **own** lawful basis and likely fails. *This is the sharpest, most concrete breach vector.*

**Door 3 — Special-category & criminal data (Art 9 & Art 10).** Linking **health records with justice / criminal data** engages the heightened regimes. Art 9 needs a specific condition; **Art 10 (criminal convictions/offences) requires official authority or specific legal authorisation**. If every linkage of NHS↔justice data doesn't independently satisfy these, it is **unlawful**. *High-value, specific.*

**Door 4 — DPIA failure (Art 35).** Large-scale linkage of sensitive data is textbook **high-risk processing** that **legally requires a Data Protection Impact Assessment** — and consultation with the regulator if high residual risk. **A missing, inadequate, or unpublished DPIA is a breach a regulator can act on directly**. *Procedural, provable, regulator-friendly.*

**Door 5 — Data minimisation & proportionality (Art 5(1)(c) + Charter Art 8 / ECHR Art 8).** "Link everything to everything" sits in tension with **minimisation**, and EU proportionality caselaw on bulk data processing (the line from *Digital Rights Ireland* / *Tele2* onward) gives a **fundamental-rights proportionality** argument: is *population-scale, indefinite, cross-domain* linkage **necessary and proportionate**, or could a narrower design achieve the public aim? *The deepest, most ambitious ground.*

## 4. How to actually pursue it (turn anger into a filing)

---

1. **Pick ONE deployment** — ideally one touching **special-category + operational use** (NHS↔justice linkage, or a real-time identification use) — that's where Doors 2 + 3 stack.

2. **File a narrow complaint** to the **ICO** (or the relevant EU DPA), pleading **transparency/fairness (Art 5(1)(a))**, **purpose limitation (Art 5(1)(b))**, **Art 9/10**, and **DPIA failure (Art 35)** — not "it's all illegal."
3. **Ask for the DPIA** (FOI / subject access can surface whether one exists and is adequate).
4. **Get a data-protection solicitor or a group like Foxglove** to pressure-test and, if it holds, escalate. Foxglove has run exactly these arguments and won.
5. **Keep the framing surgical:** lawful basis exists *but* fails on transparency, purpose, special-category conditions, and DPIA — *for this deployment*.

## 5. The honest bottom line

---

- **Not a blanket GDPR violation.** Say so — it's what makes you credible.
- **But genuinely exposed** on transparency, function creep, special-category/criminal data, and DPIAs — and challengeable on proportionality.
- **"No opt-out" is the moral core and a supporting argument, not the legal hammer.**
- **The accurate, narrow case is the one that fucks them up.** The overclaim is the one that fucks *you*.

*Not legal advice. Engage a data-protection solicitor before filing anything. Every article reference should be checked against current UK GDPR / EU GDPR text and guidance by that solicitor.*